Título em Português

Health In Sight: portal de informação em saúde com autenticação segura e conformidade com a LGPD

Resumo

Objetivo: desenvolver e avaliar um portal web de informação em saúde, sem finalidade diagnóstica, que incorpore autenticação multifator, criptografia, recuperação segura de senha, auditoria e conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD). **Métodos:** estudo de desenvolvimento tecnológico realizado em 2026 na disciplina de Políticas de Segurança da Informação. O sistema foi construído em Python 3.12, Django 5.2 e MySQL 8, a partir de requisitos funcionais e não funcionais, modelagem de ameaças STRIDE, entregas versionadas e 92 testes automatizados, com varredura de segredos, dependências e código a cada publicação. As senhas são armazenadas com Argon2id (64 MiB, três iterações, salt único); o segundo fator usa TOTP, com segredo cifrado em AES-256-GCM; a recuperação de senha emprega token de 256 bits, de uso único e validade de 30 minutos, guardado apenas como hash SHA-256; o tráfego é protegido por TLS 1.3 e HSTS; e os eventos de autenticação formam uma trilha encadeada por hash. Para a LGPD, adotaram-se minimização de dados, consentimento por finalidade com data e versão, revogação, e consulta, exportação e exclusão dos dados pelo titular. A avaliação comparou o código com um checklist de 68 requisitos, com execução local. **Resultados:** dos 42 requisitos de segurança, 33 foram atendidos e 9 parcialmente, sem nenhum ausente; entre os 15 riscos mapeados, nenhum foi classificado como crítico. **Conclusão:** os mecanismos de proteção de credenciais e dados mostraram-se adequados; as lacunas restantes concentram-se no acesso administrativo, na gestão de chaves e na disponibilidade, e orientam as próximas versões.

Palavras-chave

Segurança Computacional; Confidencialidade; Autenticação Multifator; Proteção de Dados Pessoais; Informação de Saúde ao Consumidor.

Title in English

Health In Sight: a health information portal with secure authentication and compliance with the Brazilian General Data Protection Law (LGPD)

Abstract

Objective: to develop and evaluate a web-based health information portal, with no diagnostic purpose, that incorporates multi-factor authentication, encryption, secure password recovery, auditing and compliance with the Brazilian General Data Protection Law (LGPD). **Methods:** a technological development study carried out in 2026 in the Information Security Policies course. The system was built with Python 3.12, Django 5.2 and MySQL 8, based on functional and non-functional requirements, STRIDE threat modeling, versioned releases and 92 automated tests, with secret, dependency and code scanning on every release. Passwords are stored with Argon2id (64 MiB, three iterations, unique salt); the second factor uses TOTP, with its secret encrypted with AES-256-GCM; password recovery uses a 256-bit single-use token valid for 30 minutes and stored only as a SHA-256 hash; traffic is protected by TLS 1.3 and HSTS; and authentication events form a hash-chained audit trail. For the LGPD, the system adopts data minimization, purpose-specific consent with date and version, revocation, and data access, export and deletion by the data subject. The evaluation compared the code against a 68-item checklist, with a local run. **Results:** of the 42 security requirements, 33 were met and 9 partially met, with none missing; among the 15 risks identified, none was rated critical. **Conclusion:** the mechanisms protecting credentials and data proved adequate; the remaining gaps lie in administrative access, key management and availability, and they guide the next versions.

Keywords

Computer Security; Confidentiality; Multi-Factor Authentication; Personal Data Protection; Consumer Health Information.

Título en Español

Health In Sight: portal de información en salud con autenticación segura y conformidad con la Ley General de Protección de Datos de Brasil (LGPD)

Resumen

Objetivo: desarrollar y evaluar un portal web de información en salud, sin finalidad diagnóstica, que incorpore autenticación multifactor, cifrado, recuperación segura de contraseña, auditoría y conformidad con la LGPD brasileña. **Métodos:** estudio de desarrollo tecnológico realizado en 2026 en la asignatura de Políticas de Seguridad de la Información. El sistema se construyó con Python 3.12, Django 5.2 y MySQL 8, a partir de requisitos funcionales y no funcionales, modelado de amenazas STRIDE, entregas versionadas y 92 pruebas automatizadas, con análisis de secretos, dependencias y código en cada entrega. Las contraseñas se almacenan con Argon2id (64 MiB, tres iteraciones, salt único); el segundo factor usa TOTP, con secreto cifrado en AES-256-GCM; la recuperación de contraseña emplea un token de 256 bits, de uso único y válido por 30 minutos, guardado solo como hash SHA-256; el tráfico usa TLS 1.3 y HSTS; y los eventos de autenticación forman un registro de auditoría encadenado por hash. Para la LGPD, se adoptaron minimización de datos, consentimiento por finalidad con fecha y versión, revocación, y consulta, exportación y eliminación de datos por el titular. La evaluación comparó el código con una lista de 68 requisitos, con ejecución local. **Resultados:** de los 42 requisitos de seguridad, 33 se cumplieron y 9 parcialmente, sin ausencias; ninguno de los 15 riesgos identificados fue crítico. **Conclusión:** los mecanismos de protección de credenciales y datos resultaron adecuados; las brechas se concentran en el acceso administrativo, la gestión de claves y la disponibilidad, y orientan las próximas versiones.

Palabras clave

Seguridad Computacional; Confidencialidad; Autenticación Multifactor; Protección de Datos Personales; Información de Salud al Consumidor.